POLARIZED SYSTEMS LLC
ENTERPRISE NETWORK & SECURITY ENGINEERING

CYBERSECURITY INCIDENT RESPONSE · GOVERNANCE, RISK & COMPLIANCE

Governance, Risk & Compliance Reference

Organization: Polarized Systems · **Environment:** corp.polarizedsystems.com · **Owner:** Security & Risk
Version: 1.0 · **Last reviewed:** October 2026 · **Review cycle:** Annual · **Classification:** Internal

Technical defenses only hold up when something larger holds them in place. Every control is a decision, and every decision needs an owner, a justification, and a way to prove it was the right call afterward. That connective tissue — who sets direction, how uncertainty is measured and handled, and how the organization demonstrates it meets its obligations — is **governance, risk, and compliance**. This reference distils a full GRC curriculum into three pillars, written to the standard a board, an auditor, and a regulator all accept.

PILLAR 1

Governance

Governance is the steering wheel of a security program: the frameworks, policies, ownership structures, and legal commitments that give every downstream technical choice a reason for existing and a person answerable for it.

Frameworks & the Risk Management Life Cycle

Mature organizations adopt an established framework and tailor it rather than inventing a program from scratch. Common choices include the **NIST Cybersecurity Framework (CSF)** (outcome-based: identify, protect, detect, respond, recover), the prescriptive **NIST Risk Management Framework (RMF)**, **ISO 31000** (enterprise risk), **COBIT** (IT–business alignment), **COSO** (internal controls), and **ITIL** (service management). Beneath any of them runs the same life cycle: **identify → assess → control → review**, repeating continuously as systems, threats, and regulations change.

> **A framework is a starting point, not a finish line.** Adopting NIST CSF or ISO 31000 does not make an organization secure — it gives the program a coherent skeleton. The real work is tailoring it to actual systems and obligations, then living the life cycle rather than filing it in a binder.

Risk Appetite vs. Tolerance, and Operational Controls

Risk appetite is the broad, strategic statement of how much risk the organization will pursue; **risk tolerance** is the specific limit around an individual risk. Leadership owns both. The **Architecture Tradeoff Analysis Method (ATAM)** weighs usability, performance, cost, and risk when deciding how a system is built. Organizational controls quietly shrink opportunities for abuse: **separation of duties**, **job rotation**, **mandatory vacations**, and disciplined **asset visibility and configuration control**.

Data Lifecycle & Classification

Classification sorts data by sensitivity (public → internal → confidential → highly sensitive), which drives who may see it, how it is stored, and how long it is kept. Every data set needs a named **owner**; **retention policies** balance business need against legal requirement; and at end-of-life, **secure destruction** makes data unrecoverable.

Sanitization Method	What It Does	Typical Use
Clearing	Overwrites so standard tools cannot recover data	Reused media staying in-house
Purging	Stronger removal (e.g., degaussing) resistant to lab recovery	Media leaving the organization
Physical destruction	Shredding, crushing, incinerating the media	Highest-sensitivity data; failed drives
Crypto-erasure	Destroys the keys so ciphertext is permanently unreadable	Encrypted drives and cloud storage

> **Improper destruction is a breach waiting to happen.** A decommissioned server or returned leased laptop still holding readable data is a textbook source of avoidable breaches and penalties — and the disposal stage is the one most often neglected.

Legal Doctrine, Contracts & AI Governance

Due care is taking the reasonable safeguards a prudent organization would; **due diligence** is the ongoing, documented effort to evaluate and improve them. When litigation is anticipated, a **litigation (legal) hold** suspends routine deletion to preserve **Electronically Stored Information (ESI)** for **eDiscovery**. Geography matters too: **jurisdiction**, **export controls**, and **encryption laws** all vary by country. Relationships with third parties are governed by written agreements:

Agreement	Purpose
MSA – Master Service Agreement	Frames a long-term relationship so projects proceed without renegotiating basics
NDA – Non-Disclosure Agreement	Binds parties to protect confidential information, usually with penalties
MOU – Memorandum of Understanding	Non-binding record of intent, often preceding a formal contract
ISA – Interconnection Security Agreement	Defines terms for securely connecting two parties' systems
SLA – Service Level Agreement	Guarantees performance (uptime, response) with penalties for misses
OLA – Operational-Level Agreement	Internal agreement between business units supporting a service
PLA – Privacy Level Agreement	Focuses on how a provider protects personal and health data

Finally, **AI and machine learning** now sit on both sides of the equation — powering UEBA and data-loss prevention on defense, while introducing **adversarial AI**, **explainability**, and training-data integrity as new governance risks.

> **STAKEHOLDER PERSPECTIVE**
>
> *"Governance is where we decide, on purpose and in advance, how this organization handles security — calmly and on the record. We pick a recognized framework, state how much risk we'll take, name an owner for every important system, and put the legal and contractual pieces in place, so that when something goes wrong we can show we acted responsibly."*

PILLAR 2

Risk Management

If governance decides how much risk is acceptable, risk management is the machinery that finds the risks, measures them, and acts on them. The goal is never to eliminate risk, but to reduce it to the level governance has declared acceptable — and to prove that is what happened.

The Four Risk Handling Strategies

Every risk is treated with some mix of four strategies: **Avoid** (remove the source), **Accept** (knowingly bear it — documented), **Transfer** (shift it via insurance or a shared-responsibility model), and **Mitigate** (reduce likelihood or impact with controls). Whatever remains afterward is **residual risk** — and it is residual risk that leadership ultimately accepts or rejects.

> **"Accept" is a decision, not an accident.** The difference between accepting a risk and ignoring it is a signature: an accepted risk is weighed, documented, and owned; an ignored risk is the same exposure with no one accountable.

Assessing Risk & the Risk Register

Quantitative analysis puts numbers on risk: **SLE = Asset Value × Exposure Factor**, and **ALE = SLE × Annualized Rate of Occurrence**. A safeguard is justified when it costs less per year than the ALE it reduces. **Qualitative** analysis uses high/medium/low categories; **semi-quantitative** blends the two. **KPIs** track whether controls achieve their goals; **KRIs** give early warning before a risk materializes. Everything identified lands in the **risk register** — a living record of each risk, its impact, its controls, and its planned response.

> **The register is what makes risk management auditable.** A one-time assessment is a snapshot; the register is the film — where an auditor confirms that risks were treated and that accepted risks were actually signed off.

Business Impact Analysis (BIA)

A BIA connects each system to the business processes it supports and sets the recovery metrics that drive every continuity decision.

Metric	Defines
MTD – Maximum Tolerable Downtime	Longest a function can be unavailable before damage is unacceptable
RTO – Recovery Time Objective	How quickly the system must be restored (within the MTD)
RPO – Recovery Point Objective	How much data, measured in time, the business can afford to lose
WRT – Work Recovery Time	Time after restoration to reach full operational integrity
RSL – Recovery Service Level	Level of service expected during recovery

> **RTO and RPO are business decisions in technical clothing.** How fast we recover and how much data we can lose determine how much we spend on backups and standby infrastructure. The BIA is where that trade-off is made explicit.

Privacy, Threat Modeling, Vendor & Assessment Risk

A **Privacy Impact Assessment (PIA)** identifies and mitigates privacy risks for **PII** across its lifecycle, is triggered by new systems or rule sets handling PII, and is run proactively and reviewed at least annually. **Threat modeling** thinks like an attacker before an attack — profiling threat actors (script kiddies, hacktivists, organized crime, nation-states/APTs, insiders, supply-chain) and mapping attack paths to prioritize defense; the supporting frameworks (Kill Chain, MITRE ATT&CK) are demonstrated hands-on in the Attack Methodology Frameworks section of this portfolio. **Vendor assessment** looks past price to viability, lock-in, SLAs, data residency, and supply-chain depth, validated by independent reports:

Assessment	Validates
SOC 2	Security, availability, and confidentiality controls at a service provider
ISO 27001	A formally audited information-security management system
CSA STAR	Cloud-specific security posture
CMMC	Cybersecurity maturity for government-contracting supply chains

Security assessments themselves are governed by a **Statement of Work (SOW)** and **Rules of Engagement (ROE)**, above which sits **formal written authorization** — the line between an authorized test and a crime. When work becomes evidence, **chain of custody**, **forensic imaging** (dd), and **hashing** (SHA-256; ssdeep for fuzzy matching) preserve its integrity.

> **STAKEHOLDER PERSPECTIVE**
>
> *"Risk management is how we stop guessing and start making decisions we can defend. We find the risks, measure them, and for each one choose deliberately: avoid, reduce, transfer, or knowingly accept and sign our name to it. We know which systems matter most and exactly how fast we'd have to recover them — and we write it all down, because a risk we've tracked and owned is a risk we can answer for."*

PILLAR 3

Compliance & Resilience

This pillar proves the program on two fronts: **compliance** — demonstrating to auditors and regulators that obligations are met — and **resilience** — keeping running, or recovering fast, when something goes wrong anyway.

Compliance, Training & Regulatory Alignment

Security awareness training is one of the highest-leverage controls, since people are the most-targeted part of any environment. Governance also follows the **employment lifecycle** — onboarding grants access and training; offboarding reliably removes it. Organizations are bound by overlapping privacy regimes:

Regulation	Scope
HIPAA	Protected health information (United States)
GDPR	Personal data of EU individuals; strong consent and erasure rights
CCPA	Consumer data privacy rights (California)
COPPA	Online collection of data from children

When regimes conflict, the practical answer is a consistent high baseline plus meticulous records. Best-practice standards — **ISO 27001**, **PCI DSS**, **CSA STAR/CCM** — guide the controls, and formal **Certification & Accreditation (C&A)** validates a system and grants an **Authority to Operate (ATO)**, backed by continuous monitoring.

> **Compliance is not the same as security — but it is how security is proven.** Meeting a standard does not guarantee safety, yet compliance is the language regulators and partners trust. A well-run program treats the two as reinforcing.

Business Continuity & Disaster Recovery

The **Business Continuity Plan (BCP)** keeps the whole organization functioning through a disruption; the **Disaster Recovery Plan (DRP)** is the narrower IT-focused plan nested within it. Recovery goals use the same **RTO/RPO** metrics from the BIA, and a central decision is the recovery site — a direct trade of cost against speed:

Site	Readiness	Recovery Time	Cost
Cold	Empty space, basic utilities	Weeks to months	Lowest
Warm	Pre-configured, equipped, powered	Hours to days	Moderate
Hot	Fully configured, continuously updated mirror	Minutes	Highest
Mobile	Portable data center (container/trailer)	Days	Varies

Disaster Recovery as a Service (DRaaS) delivers the same capability from the cloud with minimal upfront investment. **NIST SP 800-34** is the recognized reference for building these plans.

> **The recovery site is the RTO made physical.** A hot site exists because some functions have an RTO of minutes; a cold site exists because others tolerate weeks and should not pay for more. The site is simply the BIA's objectives translated into infrastructure.

Testing the Plans

An untested plan is a hypothesis, and testing is often a legal requirement. The methods form a spectrum from least to most disruptive:

Test	What Happens	Intrusiveness
Checklist	Plan reviewed on paper for accuracy and gaps	Least
Walkthrough	Representatives discuss and talk through the plan	Low
Tabletop (TTX)	Facilitated scenario discussion — no live systems touched	Moderate
Parallel	Recovery site brought online in isolation; selected teams operate from it	High
Full interruption	Complete failover of all systems to the recovery site	Most

Incident response is a whole-organization effort (**NIST SP 800-61**), drawing in management, legal, HR, IT, and more; **NIST SP 800-84** guides exercise programs. Every meaningful test ends in an **After Action Report (AAR)** capturing findings and recommendations — the output that turns a test into genuine improvement and feeds the next governance cycle.

> **STAKEHOLDER PERSPECTIVE**
>
> *"This is where we prove it. Compliance is being able to show — to a regulator, a customer, an auditor — that we do what we're required to do, with the records to back it up. Resilience is being able to keep running when something gets through. And we test our plans before we need them, because the middle of a real incident is the worst time to discover the plan doesn't work. A plan on a shelf is a wish; a plan we've rehearsed is a capability."*